

Network Security Assessment

Scope Authorization & Rules of Engagement

Stage 1 — Internal Network Analysis, Scanning & Vulnerability Assessment

Document ID	SEC-AUTH-2026-01	Version	1.0
Project	Sentinel SOC	Effective date	___ / ___ / 2026
Classification	CONFIDENTIAL — Internal Use Only	Valid through	___ / ___ / 2026

1. Purpose

This document formally authorizes the named security assessment team to conduct a defensive, internal security assessment of the organization's own network infrastructure, and defines the agreed rules of engagement. The objective of Stage 1 is to identify open ports, insecure services, basic vulnerabilities, and — above all — to evaluate how the network is segmented (VLANs, subnets, and routing between them). Active exploitation and penetration testing are explicitly out of scope for Stage 1 and are deferred to a separately authorized Stage 2.

2. Parties

Authorizing organization: _____

Business sponsor / approving manager: _____

IT / Infrastructure owner: _____

Assessment lead (Security): _____

The assessment team acts in good faith and strictly within the scope and schedule defined below. Any activity outside this scope requires prior written authorization.

3. Scope — Authorized Targets

The following networks are IN SCOPE for this assessment. List every authorized range, subnet, and VLAN. Only assets the organization owns and is authorized to test may be listed.

#	Description / Zone	IP Range or CIDR	VLAN	Notes

Explicitly OUT OF SCOPE (must not be scanned or touched):

#	Excluded system / range	Reason

#	Excluded system / range	Reason

4. Authorized Activities

- Host discovery / liveness sweeps (ICMP, ARP, TCP SYN) across in-scope ranges.
- TCP/UDP port scanning and service / version detection (e.g., nmap, zmap for internal discovery).
- Non-destructive vulnerability scanning (e.g., nmap NSE “vuln” scripts) on reachable hosts.
- Cross-segment reachability testing to evaluate VLAN / subnet isolation (the segmentation audit).
- Passive traffic observation on an authorized interface (read-only; no injection).
- Documentation of findings into the assessment platform (Sentinel SOC).

5. Prohibited Activities (Stage 1)

- **No exploitation.** Exploitation of vulnerabilities, privilege escalation, or installation of any tooling on target hosts.
- **No disruption.** Denial-of-service, stress, or flooding tests of any kind.
- **No credentials.** Password brute-forcing, credential capture, or offline cracking.
- **No social eng.** Social engineering, phishing of staff, or physical intrusion.
- **No data access.** Accessing, copying, altering, or deleting business data.
- **No out-of-scope.** Scanning any system not listed as in scope.

6. Authorized Tools

nmap, zmap (internal-range configuration), tshark (passive capture, Stage 2), and the Sentinel SOC detection scripts. Any additional tool must be approved in writing before use.

7. Schedule & Time Window

Parameter	Value
Assessment start date	
Assessment end date	
Permitted scanning hours	e.g., 19:00 – 06:00 (outside business hours)
Blackout periods (no scanning)	
Intrusive vuln scans coordinated with IT?	Yes ☐ Scheduled window: _____

8. Authorized Personnel

Name	Role	Email / Phone

9. Emergency Contacts & Stop Conditions

If any system becomes unstable or unavailable during the assessment, the team will immediately stop the activity, notify the contacts below, and document the event. Scanning resumes only after IT confirms it is safe to proceed.

Primary IT emergency contact (name / phone): _____

Secondary contact (name / phone): _____

- **Stop conditions:** Stop immediately if a host or service goes down, if unexpected production impact is observed, or on request from IT.

10. Data Handling & Confidentiality

All assessment output (host inventories, open ports, vulnerabilities, network maps) is CONFIDENTIAL and reveals the internal structure of the network. It will be stored only on authorized systems, shared only with the parties to this authorization, and retained per the organization's data-retention policy. Findings will not be disclosed to any third party without written approval.

11. Risk Acknowledgment

The parties acknowledge that network scanning carries an inherent, low but non-zero risk of service disruption, particularly against fragile or legacy devices. The assessment team will use non-destructive settings and coordinate intrusive scans with IT. By signing below, the authorizing organization accepts this residual risk and confirms it owns, or is duly authorized to test, every in-scope target.

12. Authorization & Signatures

By signing, each party confirms they have read, understood, and approved the scope and rules of engagement defined in this document.

Approving Manager / Business Sponsor

Signature

Date

Printed name: _____

Title: _____

IT / Infrastructure Owner

Signature

Date

Printed name: _____

Title: _____

Assessment Lead (Security)

Signature

Date

Printed name: _____

Title: _____

Appendix A — Revision History

Version	Date	Author	Change
1.0			Initial authorization

Version	Date	Author	Change